NOVATECH SOLUTIONS - AUDITORÍA DE SEGURIDAD INDEPENDIENTE

- **Rol Simulado:** Junior Risk Analyst / Information Security Evaluator
- **Organización Simulada:** NovaTech Solutions (PyME híbrida de 35 empleados)
- **Marcos y Conceptos Aplicados:** NIST SP 800-30 Rev. 1, Risk Assessment, Threat Identification, Vulnerability Prioritization, Asset Management, CIA Triad, Security Controls.
- **Contexto del proyecto:** Evaluación de seguridad simulada con fines formativos, centrada en la identificación, evaluación y priorización de riesgos de infraestructura tecnológica en una empresa ficticia.

1. Alcance de la Auditoría (Scope)

El alcance de la evaluación comprende la infraestructura tecnológica y de información de NovaTech Solutions, incluyendo estaciones de trabajo Windows, notebooks corporativas, red Wi-Fi interna y corporativa, servidor de archivos, servicios de almacenamiento en la nube, cuentas de usuario, mecanismos de acceso remoto y procedimientos operativos de TI y Recursos Humanos.

La evaluación se enfoca en identificar vulnerabilidades técnicas y debilidades operativas que puedan comprometer la confidencialidad, integridad y disponibilidad de los activos de información de la organización.

2. Objetivos (Goals)

- Evaluar la postura de seguridad actual de la organización mediante una metodología de gestión de riesgos basada en NIST SP 800-30 Rev. 1.
- Identificar vulnerabilidades técnicas y debilidades operativas derivadas del crecimiento de la empresa y de la adopción del modelo de trabajo híbrido.
- Analizar y priorizar los riesgos identificados en función de su probabilidad e impacto sobre la Tríada CIA: Confidencialidad, Integridad y Disponibilidad.
- Identificar los controles de seguridad existentes y determinar cuáles necesitan implementarse o mejorarse.
- Proporcionar recomendaciones técnicas aplicables y un plan de mitigación para fortalecer el nivel de seguridad de la empresa.

3. Activos Principales (Assets)

Los principales activos tecnológicos y de información considerados durante la evaluación son:

- **Equipos de cómputo:** computadoras de escritorio y notebooks corporativas utilizadas por los empleados.
- **Infraestructura de red:** firewall perimetral y red Wi-Fi interna y corporativa.

- **Servidores y almacenamiento:** servidor de archivos interno y repositorios de almacenamiento en la nube.
- **Cuentas y credenciales:** cuentas de usuario, credenciales de acceso y directorios de autenticación.
- **Información corporativa:** datos de clientes, documentación interna y datos personales de los empleados.
- **Accesos y procedimientos:** mecanismos de acceso remoto y procesos de gestión de altas y bajas de usuarios.

Estos activos requieren controles adecuados para reducir el riesgo de accesos no autorizados, pérdida de información, interrupciones operativas y otros incidentes de seguridad.

4. Riesgos y Vulnerabilidades Identificados

Durante la revisión inicial de la infraestructura y los procesos de NovaTech Solutions, se identificaron las siguientes vulnerabilidades y debilidades principales:

a. **Cifrado de dispositivos:** Los equipos portátiles (notebooks) corporativos no cuentan con cifrado de disco completo (*Full Disk Encryption* o FDE). Esta condición puede permitir el acceso a información almacenada localmente en caso de pérdida o robo de un dispositivo.
b. **Control de accesos:** Se identificaron permisos de usuario excesivos que no respetan adecuadamente el principio de mínimo privilegio (*Least Privilege*). Esto puede permitir que algunos empleados accedan a información o recursos que no necesitan para cumplir sus funciones.
c. **Autenticación:** Las cuentas utilizan contraseñas con una longitud mínima de ocho caracteres, pero no cuentan con autenticación multifactor (*Multi-Factor Authentication* o MFA). La ausencia de un segundo factor de autenticación aumenta la exposición ante el compromiso de credenciales.
d. **Acceso remoto:** Los empleados que trabajan de forma remota acceden a recursos corporativos sin utilizar una VPN corporativa. Esto aumenta la exposición de las comunicaciones y los recursos internos cuando se utilizan redes externas o no confiables.
e. **Detección de amenazas:** La infraestructura no dispone de un sistema de detección de intrusiones (*Intrusion Detection System* o IDS) para monitorear el tráfico de red y generar alertas ante posibles actividades maliciosas.
f. **Respaldo y recuperación:** Las copias de seguridad se realizan manualmente, sin un calendario definido ni pruebas formales de restauración. Además, la organización no dispone de un plan documentado de recuperación ante desastres (*Disaster Recovery Plan* o DRP).
g. **Gestión de activos:** La empresa no cuenta con un inventario actualizado de todos sus activos tecnológicos, lo que dificulta identificar, administrar y proteger adecuadamente los recursos existentes.

h. **Factor humano:** La capacitación en seguridad se limita principalmente al proceso de incorporación de nuevos empleados (*onboarding*). No existe un programa periódico de concientización que permita reforzar las buenas prácticas y preparar a los usuarios frente a amenazas como el phishing y la ingeniería social.
i. **Ciclo de vida de los accesos (Offboarding):** Existe un procedimiento operativo de comunicación entre Recursos Humanos y TI para gestionar las bajas de personal y eliminar sus accesos. Sin embargo, el procedimiento no está formalmente documentado, lo que puede generar inconsistencias o demoras en su ejecución.

5. Controles Existentes (Existing Security Controls)

Durante la evaluación se identificaron los siguientes controles de seguridad existentes:

- Firewall perimetral activo.
- Software antivirus instalado en los equipos y sujeto a actualizaciones periódicas.
- Cuentas de usuario individuales para acceder al servidor.
- Requisito mínimo de longitud de ocho caracteres para las contraseñas.
- Medidas de seguridad física en las oficinas, incluyendo cerraduras y cámaras de vigilancia.
- Copias de seguridad existentes, aunque su gestión es manual.
- Capacitación inicial en seguridad al incorporar nuevos empleados.
- Comunicación operativa entre Recursos Humanos y TI para eliminar los accesos cuando se producen bajas de personal.

Estos controles constituyen una base inicial de protección. Sin embargo, su existencia no elimina la necesidad de fortalecer los mecanismos de prevención, detección, recuperación y gestión de accesos.

6. Controles Faltantes o que Deberían Mejorarse (Missing / Weak Security Controls)

A partir de los riesgos identificados, se considera necesario implementar o mejorar los siguientes controles:

a. **Cifrado de disco completo (Full Disk Encryption):** implementar cifrado en las notebooks corporativas para proteger la información almacenada ante pérdidas o robos.
b. **Principio de mínimo privilegio (PoLP):** revisar y limitar los permisos de los usuarios de acuerdo con sus responsabilidades laborales, incluyendo controles adecuados de separación de funciones.
c. **Autenticación multifactor (MFA):** incorporar un segundo factor de autenticación, priorizando las cuentas privilegiadas y los accesos remotos.
d. **Acceso remoto seguro mediante VPN:** establecer mecanismos de conexión segura para los empleados que acceden a recursos corporativos desde redes externas.

e. **Sistema de detección de intrusiones (IDS):** mejorar la visibilidad del tráfico de red y habilitar alertas tempranas ante comportamientos potencialmente maliciosos.
f. **Gestión de copias de seguridad y recuperación:** automatizar y calendarizar los respaldos, realizar pruebas periódicas de restauración y desarrollar un plan de recuperación ante desastres (DRP) documentado.
g. **Gestión de activos (Asset Management):** crear y mantener un inventario centralizado y actualizado de los activos tecnológicos.
h. **Capacitación y concientización en seguridad (Security Awareness Training):** establecer un programa periódico de formación para los empleados.
i. **Procedimiento formal de bajas (Offboarding):** documentar las responsabilidades y los pasos necesarios para revocar los accesos de los empleados que dejan la organización.

7. Priorización de Riesgos (Risk Assessment & Prioritization)

La siguiente matriz presenta la evaluación cualitativa de los riesgos identificados, considerando su probabilidad de ocurrencia, el impacto potencial y la prioridad asignada.

N.º	Hallazgo	Probabilidad	Impacto	Prioridad
1	Equipos corporativos sin cifrado	Media	Alto	**ALTA**
2	Permisos excesivos / falta de mínimo privilegio	Media	Alto	**ALTA**
3	Ausencia de autenticación multifactor (MFA)	Media	Medio	**MEDIA**
4	Acceso remoto sin VPN	Media	Alto	**ALTA**
5	Ausencia de sistema de detección de intrusiones (IDS)	Media	Alto	**ALTA**
6	Backups deficientes y ausencia de DRP	Media	Alto	**ALTA**
7	Inventario de activos desactualizado	Media	Alto	**ALTA**
8	Falta de capacitación periódica en seguridad	Alta	Medio	**ALTA**
9	Procedimiento de offboarding no formalizado	Media	Medio	**MEDIA**

Interpretación de la matriz:

Los resultados permiten identificar como prioritarios los riesgos relacionados con la falta de cifrado de los equipos, los permisos excesivos, el acceso remoto sin VPN, la ausencia de un IDS, las deficiencias en las copias de seguridad y la falta de un inventario actualizado.

La ausencia de capacitación periódica también recibe prioridad alta debido a la mayor probabilidad estimada de incidentes asociados al factor humano.

Por su parte, la ausencia de MFA y la falta de formalización del procedimiento de offboarding se clasifican con prioridad media en esta evaluación cualitativa. Esto no significa que deban ignorarse, sino que deben abordarse de acuerdo con la priorización establecida y el contexto de riesgo de la organización.

La matriz representa una estimación cualitativa y no una medición estadística de incidentes reales.

8. Recomendaciones de Seguridad (Security Recommendations)

1. Equipos corporativos sin cifrado — Prioridad: ALTA

Hallazgo: La ausencia de cifrado de disco completo podría permitir el acceso no autorizado a información corporativa en caso de pérdida o robo de un dispositivo. Esto afecta principalmente a la confidencialidad de los datos almacenados.

Recomendación: Implementar cifrado de disco completo (FDE) en los equipos corporativos y establecer políticas para la administración segura de notebooks y otros dispositivos portátiles.

2. Permisos excesivos y falta de mínimo privilegio — Prioridad: ALTA

Hallazgo: Algunos empleados tienen acceso a carpetas e información que no necesitan para desempeñar sus funciones. Esta situación incumple el principio de mínimo privilegio y puede exponer los datos a modificaciones, divulgaciones o accesos no autorizados.

Recomendación: Revisar los permisos vigentes y reestructurar los accesos basándose en las funciones laborales de cada usuario. Establecer revisiones periódicas de permisos y aplicar controles adecuados de separación de funciones.

3. Ausencia de autenticación multifactor (MFA) — Prioridad: MEDIA

Hallazgo: Las cuentas utilizan contraseñas de al menos ocho caracteres, pero no disponen de autenticación multifactor. Si las credenciales de un usuario se ven comprometidas, la ausencia de un segundo factor puede facilitar el acceso no autorizado.

Recomendación: Implementar MFA, priorizando las cuentas con privilegios elevados y los accesos remotos. Verificar que los mecanismos de autenticación estén correctamente configurados y que existan procedimientos seguros para recuperar el acceso a las cuentas.

4. Acceso remoto sin VPN — Prioridad: ALTA

Hallazgo: El acceso de empleados remotos desde redes externas o no confiables aumenta la exposición de las comunicaciones y los recursos corporativos.

Recomendación: Implementar mecanismos seguros de acceso remoto mediante una VPN corporativa y verificar que las conexiones utilicen controles apropiados de autenticación y cifrado.

5. Ausencia de un sistema de detección de intrusiones (IDS) — Prioridad: ALTA

Hallazgo: La falta de un IDS disminuye la capacidad de la organización para detectar y generar alertas ante patrones de tráfico potencialmente maliciosos. Como consecuencia, una posible intrusión podría permanecer sin detectar durante más tiempo.

Recomendación: Implementar capacidades de monitoreo y detección de red mediante un IDS. Establecer procedimientos para revisar las alertas, analizar los eventos sospechosos y responder oportunamente ante posibles incidentes.

6. Gestión deficiente de backups y ausencia de un plan de recuperación ante desastres (DRP) — Prioridad: ALTA

Hallazgo: Las copias de seguridad manuales, la ausencia de una periodicidad definida, la falta de pruebas de restauración y la inexistencia de un DRP documentado exponen a la empresa a pérdidas importantes de información y a interrupciones operativas ante incidentes graves, como ataques de ransomware.

Recomendación: Establecer una política formal de respaldos, automatizar las copias de seguridad y supervisar su ejecución. Realizar pruebas periódicas de restauración para comprobar que la información pueda recuperarse correctamente. Desarrollar y documentar un plan de recuperación ante desastres que defina responsabilidades, procedimientos y acciones para restablecer los servicios críticos.

7. Inventario de activos desactualizado — Prioridad: ALTA

Hallazgo: La falta de un inventario completo y actualizado dificulta identificar qué recursos deben protegerse, mantenerse, actualizarse o monitorearse. Esto puede aumentar la superficie de ataque de la organización.

Recomendación: Implementar y mantener actualizado un inventario centralizado de activos tecnológicos. Registrar, como mínimo, los equipos, servidores, dispositivos de red y recursos relevantes, junto con sus responsables y estado de gestión.

Principio de referencia: No es posible proteger adecuadamente los activos que la organización desconoce o no tiene identificados.

8. Falta de capacitación periódica en seguridad — Prioridad: ALTA

Hallazgo: La ausencia de formación continua aumenta la exposición a campañas de phishing, ingeniería social, robo de credenciales y otros incidentes relacionados con errores humanos.

Recomendación: Desarrollar un programa periódico de concientización en seguridad (*Security Awareness Training*). Incluir buenas prácticas para el uso de contraseñas, identificación de correos sospechosos, protección de la información y notificación de incidentes.

9. Proceso de offboarding no formalizado — Prioridad: MEDIA

Hallazgo: Aunque existe un proceso operativo de comunicación entre Recursos Humanos y TI para gestionar las bajas de accesos, la falta de documentación formal puede generar fallas de comunicación, demoras o cuentas activas que deberían haber sido deshabilitadas.

Recomendación: Documentar formalmente el procedimiento de baja de accesos y las responsabilidades de cada área. Establecer una secuencia de acciones para deshabilitar

cuentas, revocar permisos y verificar la finalización del proceso cuando un empleado deja la organización.

9. Conclusión

La evaluación de seguridad de NovaTech Solutions permitió identificar los controles existentes y las principales áreas de mejora en su infraestructura tecnológica y en sus procesos operativos.

Aunque la organización cuenta con medidas preventivas básicas, como antivirus, firewall, cuentas individuales, requisitos mínimos para las contraseñas y controles de seguridad física, se identificaron vulnerabilidades que pueden afectar la confidencialidad, integridad y disponibilidad de sus activos de información.

Entre los riesgos prioritarios se encuentran la falta de cifrado en los equipos portátiles, los permisos excesivos, el acceso remoto sin VPN, la ausencia de un sistema de detección de intrusiones, las deficiencias en la gestión de copias de seguridad y la falta de un inventario actualizado. También se identificó la necesidad de fortalecer la capacitación periódica y formalizar determinados procedimientos operativos.

La priorización cualitativa de los riesgos permitió organizar las recomendaciones según su nivel de prioridad y orientar las acciones de mitigación hacia los aspectos más relevantes de la postura de seguridad.

La implementación progresiva de los controles recomendados contribuiría a mejorar la protección de los activos tecnológicos, reducir la exposición a incidentes y fortalecer los procesos de prevención, detección y recuperación de la organización.

En conclusión, esta evaluación simulada demuestra la importancia de aplicar una metodología estructurada de gestión de riesgos, como la propuesta en NIST SP 800-30 Rev. 1, para identificar vulnerabilidades, establecer prioridades y proponer medidas de seguridad acordes con las necesidades de una empresa.